Security In The Cloud – Assignment-4

1. Download a sample IAM policy JSON (for example, from AWS documentation), identify all users and their permissions, and list any permissions that are broader than necessary for typical user actions.




```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Sid": "AllowS3Access",
            "Effect": "Allow",
            "Action": [
                "s3:ListAllMyBuckets",
                "s3:ListBucket",
                "s3:GetBucketLocation",
                "s3:PutObject",
                "s3:GetObject",
                "s3:DeleteObject"
            ],
            "Resource": [
                "*",
                "arn:aws:s3:::student-files",
                "arn:aws:s3:::student-files/*"
            ]
        }
    ]
}
```

2. Edit the given IAM policy to implement least privilege access for a food delivery app scenario (e.g., only allow delivery agents to update order status, not delete orders), and save your revised policy as optimized_policy.json.




```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Sid": "AllowDeliveryAgentsToUpdateOrderStatusOnly",
            "Effect": "Allow",
            "Action": "dynamodb:UpdateItem",
            "Resource": "arn:aws:iam::588966314778:user/Dhrumit",
            "Condition": {
                "ForAllValues:StringEquals": {
                    "dynamodb:Attributes": [
                        "OrderId",
                        "OrderStatus"
                    ]
                },
                "StringEqualsIfExists": {
                    "dynamodb:ReturnValues": [
                        "NONE",
                        "UPDATED_NEW"
                    ]
                }
            }
        }
    ]
}
```

3. Review an IAM policy that grants full S3 access to a group called 'AppUsers' and modify it so users can only read from a specific bucket named 'user-uploads', not write or delete files. Hint Use the 'Action' and 'Resource' fields to restrict permissions.

Security In The Cloud – Assignment-4



4. Write a checklist of 5 steps you would follow to regularly review IAM policies for a movie ticket booking app (like BookMyShow), including how you would identify unused permissions and revoke them.

Checklist: Regular IAM Policy Review for a Movie Ticket Booking App

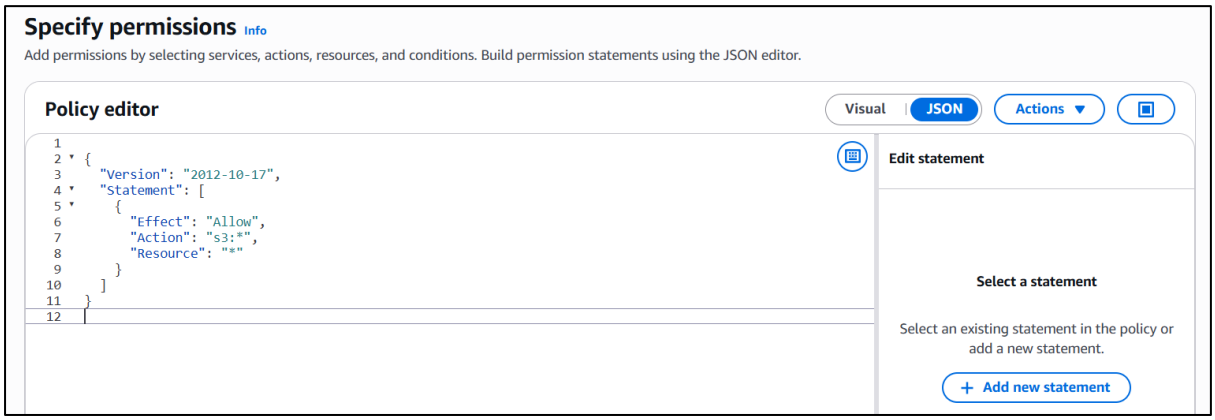
For a movie ticket booking app like BookMyShow, IAM policies should be reviewed regularly to protect customer details, payment systems, and booking records.

- 1. Review IAM users, groups, and roles. Open the AWS IAM dashboard and identify who has access to services such as EC2, S3, and DynamoDB. Remove access for inactive users and employees who no longer need it.
- 2. Check for excessive permissions. Look for policies containing broad permissions such as s3:*, dynamodb:*, or "Action": "*". Replace them with specific actions, such as allowing booking staff to view booking records without deleting them.
- 3. Identify unused permissions. Use IAM Access Analyzer and the IAM last accessed information to identify permissions and services that have not been used. Review the findings before removing permissions, since some access may be needed only occasionally.
- 4. Revoke unnecessary permissions. Edit or detach policies that grant unused or excessive access. For example, remove dynamodb:DeleteItem from a booking support role if it only needs to view booking details. Test the changes to avoid disrupting the booking service.
- 5. Schedule regular audits and document changes. Review policies monthly or after major application changes. Use AWS CloudTrail to monitor relevant access activity, document policy updates, and investigate unexpected actions.

Security In The Cloud – Assignment-4

5. Use ChatGPT or another AI tool to analyze a provided IAM policy snippet and suggest at least two improvements to enhance security following best practices. Hint: Paste the policy into the AI tool and ask for recommendations based on least privilege and regular review.

Sample Policy:



Modify Policy:

